

PART B — Q&A; Preparation

NovaPay Digital Bank | Day 11 TRC / Interview Preparation

Assessment basis: risk-focused TRC narrative, compliance evidence, business impact, architecture, rollout, rollback, observability, implementation timeline and Q&A; preparation.

Q1. 1. What is the main problem with NovaPay's current deployment model?

Interview answer: NovaPay is using manual SSH deployments. The assessment baseline includes a 4.5-hour MTTR, fortnightly deployments, three production incidents in Q4 2025, no automated compliance scanning, 17 outstanding RBI audit non-conformances and no observability. The core problem is that delivery is slow, manual, difficult to audit and difficult to recover safely.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q2. 2. What are you asking the TRC to approve?

Interview answer: I am asking the TRC to approve a controlled transformation to an automated, zero-downtime CI/CD platform. The approval is conditional on mandatory security and compliance gates, segregation of duties, observable production deployments, tested rollback and retained audit evidence.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q3. 3. Why CI/CD for a banking application?

Interview answer: CI/CD is not only about speed. For NovaPay it standardizes how changes are built, tested, secured, approved, deployed and recovered. Automation reduces manual error while hard gates make risk controls repeatable and auditable.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q4. 4. What are the eight canonical pipeline stages?

Interview answer: Source control; build; SAST; dependency and container scanning; integration and contract testing; DAST; policy and compliance gates; deployment with verification. Each stage has a clear purpose and produces evidence.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q5. 5. How do you stop an unsafe change?

Interview answer: A blocking gate fails the pipeline. For example, a critical SAST finding, prohibited dependency, failed Kubernetes policy or unsigned image stops promotion. The failure is recorded, remediation is performed and the pipeline is rerun. Exceptions require the formal approval workflow.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q6. 6. Why do you need both SAST and DAST?

Interview answer: SAST examines the source/code before deployment. DAST tests the running application from the outside. They identify different classes of security problems, so both are part of the defense-in-depth model.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q7. 7. What is the purpose of the SBOM?

Interview answer: An SBOM provides a structured inventory of software components in the artifact. It supports dependency visibility, vulnerability assessment, traceability and evidence for supply-chain controls.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q8. 8. Why is image signing important?

Interview answer: Signing provides evidence that the image being deployed is the approved artifact. Admission/policy controls can reject an unsigned or untrusted image, reducing supply-chain and unauthorized-artifact risk.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q9. 9. Explain the environment promotion model.

Interview answer: The flow is DEV → STAGING → PRE-PROD → PRODUCTION. We build once and promote the same immutable artifact. Environment-specific configuration changes, not the application artifact. Production has independent

Release Manager and SRE Lead approval.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q10. 10. What does segregation of duties mean here?

Interview answer: The person who develops a change should not have uncontrolled authority to approve and deploy it to production. The design uses protected branches, peer review and independent production approvals to reduce unauthorized or conflicted changes.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q11. 11. Why use blue-green deployment?

Interview answer: Blue-green maintains a stable environment and a candidate environment. The candidate is validated before traffic is switched. If the new version fails, traffic can be returned to the stable environment quickly. This supports zero planned downtime and fast recovery.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q12. 12. Why use canary deployment?

Interview answer: Canary exposes a small, controlled amount of traffic to the candidate first. Metrics and business outcomes are compared before increasing exposure. This limits blast radius when a defect or performance regression exists.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q13. 13. How do you decide whether a canary is safe?

Interview answer: I evaluate operational thresholds, SLOs, business metrics and statistical evidence. Welch's t-test is used for latency comparison and chi-squared testing for categorical success/error outcomes. A statistical result never replaces operational safety thresholds.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q14. 14. What are your Category A rollback triggers?

Interview answer: Immediate rollback target is below 60 seconds for conditions such as HTTP 5xx above 5% for 60 seconds, three consecutive health failures, OOMKill, CrashLoopBackOff, database connection-pool exhaustion and critical synthetic payment failure.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q15. 15. What are Category B triggers?

Interview answer: Category B is escalated with a target below 15 minutes: p99 above two times baseline for five minutes, error-budget burn above ten times normal for ten minutes, transaction success more than 2% below baseline, CPU above 90% for five minutes or memory above 85% for five minutes.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q16. 16. What is Category C?

Interview answer: Category C covers issues that need human judgment, such as gradual degradation below automation thresholds, customer-support reports, retroactive compliance failures and downstream dependency correlation.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q17. 17. Why must rollback be independent of the deployment path?

Interview answer: If the primary deployment path is the thing that failed, relying on that same path to recover can increase recovery time and risk. The rollback mechanism must remain available independently so service can be restored quickly.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q18. 18. How do you achieve zero-downtime database migration?

Interview answer: Use expand → migrate → verify → contract. First add backward-compatible schema, then run an application version that supports old and new schema, migrate/backfill in controlled batches, verify integrity and performance, and remove obsolete schema only after safe adoption.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q19. 19. How is application rollback different from payment rollback?

Interview answer: Rolling an application version back does not automatically reverse a financial transaction. Payment state must remain correct, so transaction reconciliation and data integrity are treated separately from application deployment rollback.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q20. 20. What does observability give the bank?

Interview answer: Observability provides metrics, logs and traces for engineering operations, management reporting and regulatory evidence. Prometheus/Grafana and Alertmanager support SLO monitoring, alerting, incident correlation and rollback decisions.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q21. 21. What are the key DORA metrics?

Interview answer: Deployment Frequency, Lead Time for Changes, Change Failure Rate and Mean Time to Recovery. The project targets multiple deployments per day, commit-to-production below two hours, change failure rate below five percent and rapid recovery, with the project incident objective below 15 minutes.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q22. 22. What is the SLO?

Interview answer: The rollback/observability controls use a 99.9% availability SLO and a 0.1% error budget. The broader project target is five-nines availability, so I would distinguish the operational SLO defined in the observability/rollback deliverables from the aspirational platform availability target.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q23. 23. How do you correlate an incident to a deployment?

Interview answer: Use a chain such as incident ID → alert → deployment ID → Git SHA → image digest → traffic/routing state → rollback action → verification. This gives both engineers and auditors traceability.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q24. 24. How do you support RBI compliance?

Interview answer: The design maps change management, segregation of duties, vulnerability management, encryption, audit trails, incident/business continuity and third-party risk controls to pipeline and operational controls. The key is not merely naming a regulation; each mapped control has evidence.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q25. 25. How do you support PCI-DSS v4.0?

Interview answer: The pipeline addresses software security, vulnerability management, application protection, change management, audit logging and security testing through SAST, DAST, dependency/container scanning, controlled changes, logging and evidence.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q26. 26. What happens when a compliance gate fails?

Interview answer: The pipeline blocks promotion. The failure, evidence and remediation are recorded. The change is corrected and rerun. If an exception is genuinely necessary, it follows the formal exception process with time-bound approval rather than an informal bypass.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q27. 27. What is Terraform doing in this project?

Interview answer: Terraform is the infrastructure-as-code layer. It makes infrastructure configuration repeatable and reviewable and separates reusable modules from environment-specific configuration.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q28. 28. What is Helm doing?

Interview answer: Helm packages the NovaPay Kubernetes application and manages environment-specific configuration through values files and templates. It keeps deployment configuration consistent and reusable.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q29. 29. What is ArgoCD doing?

Interview answer: ArgoCD implements GitOps reconciliation. The approved repository state is the source of truth, and ArgoCD continuously reconciles the Kubernetes environment toward that desired state.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q30. 30. Why use all three: Terraform, Helm and ArgoCD?

Interview answer: They solve different layers. Terraform manages infrastructure, Helm packages/configures the application, and ArgoCD manages Kubernetes application delivery from Git. Together they create repeatable infrastructure and controlled GitOps deployment.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q31. 31. What is the business value of this architecture?

Interview answer: It reduces deployment risk and recovery time while increasing delivery frequency. It also makes compliance evidence and change traceability systematic. For a financial platform, reliability, controlled change and auditability are business requirements, not optional engineering features.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q32. 32. What happens during a high-traffic period?

Interview answer: High-traffic windows include salary days, month-end, major festivals, RBI settlement windows, regulatory filing deadlines and marketing campaigns. Deployments within 48 hours of such windows require performance-test consideration.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q33. 33. What performance signals do you monitor?

Interview answer: The observability strategy highlights CPU above 70%, queue depth above 1000 and p99 latency above 300 ms as performance/autoscaling signals. Higher rollback thresholds exist for severe CPU, memory or latency conditions.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q34. 34. How do you prove a production change to an auditor?

Interview answer: I can show the commit, PR/review, security/compliance gate results, SBOM, image digest/signature, approval records, deployment revision, routing state, verification results and any rollback/incident evidence. The chain is designed to be auditable end to end.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q35. 35. Why should the TRC approve frequent deployments?

Interview answer: Because frequency is not the control; controlled automation is. Each release must pass testing, security, compliance, approval, progressive delivery and verification controls. Smaller changes can reduce blast radius while observability and rollback limit impact.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q36. 36. What is the biggest residual risk?

Interview answer: Even with automation, configuration errors, unknown application behavior, database compatibility issues and downstream dependencies can still cause incidents. Therefore the architecture relies on progressive delivery, strong observability, rollback, migration discipline and continuous review rather than assuming gates eliminate all risk.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q37. 37. If a TRC member asks, 'Can you guarantee zero downtime?', what do you say?

Interview answer: I would not claim an absolute guarantee. The design provides zero planned downtime and strong controls to minimize service interruption: blue-green/canary, health checks, SLO monitoring, rapid rollback and

backward-compatible database migration. Residual risk is managed and evidenced.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q38. 38. What would you monitor after production deployment?

Interview answer: Health/readiness, HTTP 5xx, p99 latency, payment success, traffic, CPU, memory, database pool, queue depth, pod restarts, SLO/error-budget burn and deployment/rollback signals. I would compare candidate behavior with the stable baseline.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q39. 39. What is the final governance principle?

Interview answer: Speed must never remove a mandatory control. The pipeline should make the safe path the easiest path: automated checks, blocking gates, independent approval, progressive deployment, rapid recovery and complete evidence.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.

Q40. 40. Give your 60-second project summary.

Interview answer: NovaPay started with manual SSH deployments, slow fortnightly releases, high MTTR, compliance gaps and no observability. I designed a production-grade CI/CD model with eight canonical stages, automated RBI/PCI-DSS-aligned compliance gates, immutable artifacts, Terraform/Helm/ArgoCD, Kubernetes, blue-green and canary deployment, expand-contract database migration, Prometheus/Grafana observability and independent rollback. The objective is to increase delivery speed while making every production change safer, observable, recoverable and auditable.

Answer technique: State the problem → explain the control → explain why it reduces risk → mention evidence/verification.